

# Domain-1 Security and Risk Management

- This domain is one of the largest with a weighting of 16%; it is also very much foundational for most of the other domains, so give it the associated time in preparation
- The Gramm-Leach-Bliley Act eliminated the Glass-Steagall Act's restrictions against affiliations between commercial and investment banks in 1999

[RFC 1087](#): activity that is unethical and unacceptable:

- (a) seeks to gain unauthorized access to the resources of the Internet
- (b) disrupts the intended use of the Internet
- (c) wastes resources (people, capacity, computer) through such actions
- (d) destroys the integrity of computer-based information, and/or
- (e) compromises the privacy of users

## 1.1 Understand, adhere to, and promote professional ethics (OSG-10 Chpts 1,19)

- As a CISSP, you must understand and follow the (ISC)<sup>2</sup> code of ethics, as well as your organization's own code
- 1.1.1 (ISC)<sup>2</sup> Code of Professional Ethics
- (ISC)<sup>2</sup> Code of Professional Ethics -- take the time to read the [code of ethics](#)
- At a minimum, know and understand the ethics canons:
  - **Protect society, the common good, necessary public trust and confidence, and the infrastructure**
    - this is “do the right thing”; put the common good ahead of yourself
    - ensure that the public can have faith in your infrastructure and security
    - any member of the public can file a claim under canon I
  - **Act honorably, honestly, justly, responsibly, and legally**
    - always follow the laws
    - but if you find yourself working on a project where conflicting laws from different countries or jurisdictions apply, you should prioritize the local jurisdiction from which you are performing the services
    - any member of the public can file a claim under canon II
  - **Provide diligent and competent service to principals**
    - avoid passing yourself as an expert or as qualified in areas that you aren't
    - maintain and expand your skills to provide competent services
    - only an employer or someone with a contractual relationship can file a complaint under canon III
  - **Advance and protect the profession**
    - don't bring negative publicity to the profession
    - provide competent services, get training and act honorably

- think of it like this: If you follow the first three canons in the code of ethics, you automatically comply with this one
  - anyone who subscribes to a code of ethics as part of their licensure or certification is eligible to file a complaint under canon IV
- 1.1.2 Organizational code of ethics
- You must also support ethics at your organization; this can be interpreted to mean evangelizing ethics throughout the organization, providing documentation and training around ethics, or looking for ways to enhance the existing organizational ethics
  - some organizations might have slightly different ethics than others, so be sure to familiarize yourself with your org's ethics and guidelines

## **1.2 Understand and apply security concepts (OSG-10 Chpt 1)**

### 1.2.1 Confidentiality, integrity, and availability, authenticity and nonrepudiation (5 Pillars of Information Security)

- **Confidentiality:**
  - Principle that objects are not disclosed to unauthorized subjects
  - Concept of measures used to ensure the protection of the secrecy of data, objects, and resources
  - Confidentiality protections prevent disclosure while protecting authorized access
  - Preserving authorized restrictions on information access and disclosure, including the means for protecting personal privacy and proprietary information
  - Sensitive data, including personally identifiable information (PII) must be kept confidential; confidentiality is different from secrecy
  - Preserving confidentiality means protecting an asset or data, even if it's not a secret
- **Integrity:**
  - Principle that objects retain their veracity and are intentionally modified only by authorized subjects
  - Concept of protecting the reliability and correctness of data; guarding against improper info modification/destruction; includes ensuring non-repudiation and authenticity
  - Integrity protection prevents unauthorized alterations of data
  - Preventing authorized subjects from making unauthorized modifications, such as mistakes
  - Maintaining the internal and external consistency of objects
- **Availability:**
  - Principle that authorized subjects are granted timely and uninterrupted access to objects
  - To ensure high availability of services and data, use techniques like failover clustering, site resiliency, automatic failover, load balancing, redundancy of hardware and software components, and fault tolerance
- **Authenticity:** ensuring a transmission, message or sender is legitimate
  - See the NIST glossary for examples: <https://csrc.nist.gov/glossary/term/authenticity>

- **Nonrepudiation:**
  - Ensures that the subject of activity or who caused an event cannot deny that the event occurred
  - Nonrepudiation is made possible through identification, authentication, authorization, accountability, and auditing
- **AAA Services:**
  - Identification: assertion of a user's identity; claiming to be an identity when attempting to access a secured area or system
  - Authentication: proving that you are that claimed identity via one or more factors of knowledge, ownership, or characteristic (something you know, something you have, something you are)
  - Authorization: defining the needed resources, permissions (i.e. allow/grant and/or deny) to a resource, and object access for a specific identity or subject
  - Auditing: recording a log of the events and activities related to the system and subjects
  - Accountability (aka accounting, aka principle of access control): proper identification, authentication, and authorization that is logged and monitored; access control process which records info about attempts by all entities to access resources; reviewing log files to check for compliance and violations in order to hold subjects accountable for their actions, especially violations of organizational security policy

## **1.3 Evaluate, apply, and sustain security governance principles (OSG-10 Chpt 1)**

- **Security governance:** the collection of policies, roles, processes/practices used to make security decisions in an org; related to supporting, evaluating, defining, and directing the security efforts of an org; it involves making sure that security strategies align with business goals, and that they are comprehensive and consistent across the organization
- Security governance is the implementation of a security solution and a management method that are tightly interconnected
- **The security function:** the aspect of operating a business that focuses on the task of evaluating and improving security over time
- To manage security, an org must implement proper and sufficient security governance
- The act of performing a risk assessment to drive the security policy is the clearest and most direct example of management of the security function
- **Third-party governance:** external entity oversight that may be mandated by law, regulation, industry standards, contractual obligation, or licensing requirement; outside investigator or auditors are often involved
- 1.3.1 Alignment of security function to business strategy, goals, mission, and objectives
- **Security Management Planning:** ensures proper creation/implementation/enforcement of a security policy, and alignment with org strategy, goals, mission, and objectives; security management is based on three types of plans: strategic, tactical, and operational

- **Strategic Plan:** a strategic plan is a long-term plan (useful for 5 years); it defines the org's security purpose
  - A strategic plan should include a risk assessment
- **Tactical Plan:** mid-term plan (1 year or less) developed to provide more details on accomplishing the goals set forth in the strategic plan
- **Operational Plan:** a short-term, highly detailed plan based on strategic or tactical plans
  - Mission, strategy, goals, and objectives — support each other in a hierarchy
  - **Objectives:** are closest to the ground-level and represent small efforts to help you achieve a mission
  - **Missions:** represent a collection of objectives, and one or more missions lead to goals; when you reach your goals, you are achieving the strategy
- A security framework must closely tie to mission and objectives, enabling the business to complete its objectives and advance the mission while securing the environment based on risk tolerance
- 1.3.2 Organizational processes (e.g., acquisitions, divestitures, governance committees)
- Security governance should address every aspect of an org, including organizational processes of acquisitions, divestitures, and governance
- Be aware of the risks in acquisitions (since the state of the IT environment to be integrated is unknown, due diligence is key) and divestitures (how to split the IT infrastructure and what to do with identities and credentials)
- Understand the value of governance committees (vendor governance, project governance, architecture governance, etc.)
- Executives, managers and appointed individuals meet to review architecture, projects and incidents (security or otherwise), and provide approvals for new strategies or directions
  - The goal is a fresh set of eyes, often eyes that are not purely focused on information security
- When evaluating a third-party for your security integration, consider the following:
  - on-site assessment
  - document exchange and review
  - process/policy review
  - third-party audit
- 1.3.3 Organizational Roles and Responsibilities
- Primary security roles are senior manager, security professional, asset owner, custodian, user, and auditor
- Senior Manager: has a responsibility for organizational security and to maximize profits and shareholder value
- Security Professional: has the functional responsibility for security, including writing the security policy and implementing it
- Asset Owner: responsible for classifying information for placement or protection within the security solution
- Custodian: responsible for the task of implementing the proscribed protection defined by the security policy and senior management
- Auditor: responsible for reviewing and verifying that the security policy is properly implemented

- 1.3.4 Security control frameworks (e.g. International Organization for Standardization (ISO), National Institute of Standards and Technology (NIST), Control Objectives for Information and Related Technology (COBIT), Sherwood Applied Business Security Architecture (SABSA), Payment Card Industry (PCI), Federal Risk and Authorization Management Program (FedRAMP))
- A **security control framework**: (AKA security frameworks) outlines the org's approach to security, including guidelines, standards and controls; a security framework is important in planning the structure of an org's security solution; frameworks include:
  - **International Organization for Standardization (ISO)**: a non-governmental org comprised of standards bodies from over 160 countries that bring global experts together to agree on best practices across a range of industries with six main products: International Standards, Technical Reports, Technical Specifications, Publicly Available Specifications, Technical Corrigenda, and Guides; ISO standards are widely used
    - **ISO/IEC 27001**: a widely recognized international standard for information security management systems (ISMS); it provides a risk-based approach, and emphasizes continual improvement of the ISMS
      - ISO 27000 series (27000, 27001, 27002, etc.) is the international security standard for implementing organizational security and includes:
        - **ISO 27000:2018**: provides an overview of the information security management system (ISMS)
        - **ISO 27001:2022**: provides best practice recommendations for an Information Security Management System (ISMS)
        - **ISO 27002:2022**: provides detailed implementation guidance for controls in ISO 27001
        - **ISO 27017:2015**: provides guidelines for information security controls applicable to the provision and use of cloud services
        - **ISO 27018:2019**: commonly accepted controls and guidelines for protecting PII in the cloud (consent, control, transparency, communication, independent, yearly audit)
    - **NIST Cybersecurity Framework (CSF)**: built around six core functions providing guidance to industry, government agencies, and other orgs to improve their ability to prevent, detect, and respond to cyber attacks, and manage cybersecurity risks
      - CSF was designed for commercial orgs and critical infrastructure and CSF 2.0 consists of these six functions:
        - govern
        - identify
        - protect
        - detect
        - respond
        - recover
    - **SP 800-53**: a comprehensive set or catalog of security and privacy controls across multiple security domains, covering areas such as risk management, access control, incident response, and system maintenance; note that 800-171

(Protecting Controlled Unclassified Information in Nonfederal Systems and Organizations) is very similar to 800-53 but applied to government agencies

- **SP 800-100**: titled Information Security Handbook: a guide for managers, NIST hasn't released an update since 2006, although they appear to have an update in progress
- **COBIT (Control Objectives for Information and Related Technologies)**: COBIT is a framework created by ISACA that focuses on enterprise IT, aligning IT and business strategies, and providing a comprehensive framework for managing risks
  - COBIT is commonly used as an *audit/compliance* framework for orgs
  - Six key principles:
    - provide stakeholder value
    - holistic approach
    - dynamic governance system
    - governance distinct from management
    - tailored to enterprise needs
    - end-to-end governance system
- **Sherwood Applied Business Security Architecture (SABSA)**: a framework and methodology for developing business-driven, risk and opportunity-focused architectures for security and risk management
  - SABSA is comprised of a series of integrated frameworks, models, methods and processes, used independently or as a holistic integrated enterprise solution, including:
    - Business Requirements Engineering Framework (known as Attributes Profiling)
    - Risk and Opportunity Management Framework
    - Policy Architecture Framework
    - Security Services-Oriented Architecture Framework
    - Governance Framework
    - Security Domain Framework
    - Through-life Security Service Management & Performance Management Framework
- **Payment Card Industry Data Security Standard PCI DSS**: a set of standards and requirements that endeavors to protect credit & debit card info
  - Key elements include:
    - Building and maintaining network security: including firewalls, at rest and in-transit encryption, and secure network configurations
    - Protecting cardholder data: including stored payment data, encrypting data transmissions, and ensuring data security measures are in place
    - Maintaining vulnerability management: developing secure systems and apps, and identification and remediation of vulnerabilities
    - Implementing strong access control: restricting physical and logical access to cardholder data to only required business functions, and assigning unique IDs to users
    - Regular monitoring and testing: testing security systems and process, and maintaining an incident response plan

- Maintaining Information Security policies: establishing policies that address information security for all personnel and outline proper cardholder data handling, and maintaining compliance audits
  - **Federal Risk and Authorization Management Program (FedRAMP)**: a government-wide program that standardizes the security assessment, authorization, and monitoring of cloud services and products; the program was established in 2011 to help the federal government use cloud technologies while protecting federal information
    - Key elements include:
      - Standardized security framework: FedRAMP provides a common set of security controls, requirements, and baselines that cloud service providers (CSPs) must meet to provide federal agency solutions
      - Security assessment and authorization: requires CSPs to undergo third-party assessment by an authorized assessment org (3PAO) to demonstrate compliance; this process leads to Authorization to Operate (ATO) or rejection
      - Continuous monitoring: FedRAMP emphasizes the importance of continuous monitoring to ensure security controls remain effective over time
      - Impact levels: categorizes services into three impact levels (low, moderate, and high) based on sensitivity of handled data; each level has specific controls
      - Agency benefits: FedRAMP provides benefits such as reduced costs and time by eliminating redundant assessments since other federal agencies can reuse an auth once a CSP obtains FedRAMP authorization, improved visibility and risk management and accelerated cloud adoption
  - **CIS Critical Security Controls**: the CIS (Center for Internet Security) Critical Security Controls provides a prioritize set of actions to defend against threats; it focuses on practical steps to reduce the attack surface, like implementing secure configurations, managing admin privileges, and monitoring logs
  - **Information Technology Infrastructure Library (ITIL)**: ITIL is a set of practices for IT service management (ITSM) that focuses on aligning IT services with business needs; it includes elements of security governance, particularly in managing security incidents, changes, and service continuity, and is often integrated with other frameworks like ISO 27001
  - **Committee of Sponsoring Organizations of the Treadway Commission (COSO)**: framework that helps orgs reduce financial fraud by establishing, assessing, and enhancing their internal controls
    - COSO's five components: Control Environment, Risk Assessment, Control Activities, Information & Communication, and Monitoring Activities.
- 1.3.5 Due care/due diligence
  - **Due diligence**: establishing a plan, policy, and process to protect the interests of the organization; due diligence is knowing what should be done and planning for it;

understanding your security governance principles (policies and procedures) and the risks to your organization; actions taken by a vendor to demonstrate or provide due care

- Due diligence often involves:
  - gathering information through discovery, risk assessments and review of existing documentation
  - developing a formalized security structure containing a security policy, standards, baselines guidelines, and procedures
  - documentation to establish written policies
  - disseminating the information to the organization
- **Due care:** practicing the individual activities that maintain the due diligence effort; due care is about your legal responsibility within the law or within org policies to implement your org's controls, follow security policies, do the right thing and make reasonable choices
- Security documentation is the security policy
- After establishing a framework for governance, security awareness training should be implemented, making sure that all new hires receive the training as then on-board, and all existing employees re-certify regularly (typically yearly)
- Due care is the responsible protection of assets
- Due diligence is the ability to prove due care

## **1.4 Understand legal, regulatory, and compliance issues that pertain to information security in a holistic context (OSG-10 Chpt 4)**

- 1.4.1 Cybercrimes and data breaches
- Understand the notification requirements placed on organizations that experience a data breach
- **Computer Fraud and Abuse Act (CFAA):** a US federal cybersecurity bill enacted in 1986 as an amendment to existing law; amended multiple times (notably in 1996, 2001, 2008), the CFAA is designed to protect computers used by the government or in interstate commerce from a variety of abuses
  - the CFAA covers a range of offenses including:
    - accessing a computer without authorization, or exceeding authorized access
    - obtaining info illegally (e.g. from gov or financial institutions)
    - committing fraud via computer/system
    - causing damage associated with DoS
    - trafficking in passwords or access creds
    - threatening to damage a computer, or to extort money/value
- **National Information Infrastructure Protection Act:** passed in 1996 as an additional set of CFAA amendments including coverage of computer systems used in international commerce, protections for additional national infrastructure, and treating as a felony any act that causes damage to critical national infrastructure
- FISMA (see below)



- California's SB 1386 implemented the first statewide requirement to notify individuals of a breach of their personnel information; all other states eventually followed suit with similar laws
- Federal breach notification requirements are not governed by a single, comprehensive law but are instead determined by a patchwork of laws covering specific industries; organizations must also comply with state laws, many of which are stricter than federal regulations
- The HIPAA Breach Notification Rule requires covered entities and their business associates to notify affected individuals, the Department of Health and Human Services (HHS), and potentially the media following a breach of unsecured protected health information (PHI) within 60 days
- Before an org expands to other countries, perform due diligence to understand legal systems and what changes might be required to the way that data is handled and secured
- In particular, be familiar with:
  - **Council of Europe Convention on Cybercrime:** a treaty signed by many countries that establishes standards for cybercrime policy
  - Laws about data breaches, including notification requirements
  - In the US, the **Health Information Technology for Economic and Clinical Health (HITECH)** Act expanded HIPAA's breach reporting requiring notification of a data breach in some cases, such as when the personal health information was not protected as required by HIPAA
    - Under the HITECH Breach Notification Rule, HIPAA-covered entities that experience a data breach must notify affected individuals, the Secretary of Health and Human Services (HHS) and the media of the breach within 60 days of discovery, when more than 500 individuals are affected
  - **Glass-Steagall Act:** passed in 1933 and separated investment and commercial banking activities and created the Federal Deposit Insurance Corporation (FDIC)
  - GLBA (Gramm-Leach-Bliley Act) applies to insurance and financial orgs, requiring notification to federal regulators, law enforcement agencies and customers when a data breach occurs
  - Certain states also impose their own requirements concerning data breaches
  - the EU and other countries have their own requirements, for instance, the GDPR has very strict data breach notification requirements: A data breach must be reported to the competent supervisory authority within 72 hours of its discovery
  - **Communications Assistance to Law Enforcement Act (CALEA):** requires all communication carriers make wiretaps possible for law enforcement officials who have an appropriate court order
  - Note that some countries do not have any reporting requirements
- 1.4.2 Licensing and Intellectual Property requirements
  - **Intellectual property:** intangible assets (e.g. software, data)
  - **Trademarks:** words, slogans, and logos used to identify a company and its products or services
  - **Patents:** provide protection to the creators of new inventions; a temporary monopoly for producing a specific item such as a toy, which must be novel and unique to qualify for a patent

- **Utility:** protect the intellectual property rights of inventors
- **Design:** cover the appearance of an invention and last for 15 years; note design patents don't protect the idea of an invention only its form, and are generally seen as weaker
- Software: area of on-going controversy; e.g. Google vs Oracle and giving to a rise of "patent trolls"
- **Copyright:** protects original works of authorship, such as books, articles, poems, and songs; exclusive use of artistic, musical or literary works which prevents unauthorized duplication, distribution or modification
- **Licensing:** a contract between the software producer and the consumer which limits the use and/or distribution of the software
- **Trade Secrets:** trade secret laws protect the operating secrets of a firm; trade secrets are intellectual property that is critical to a business, and significant damage would result if it were disclosed to competitors or the public; the Economic Espionage Act imposes fines and jail sentences on someone found guilty of stealing trade secrets from a US corp
- 1.4.3 Import/export controls
- Every country has laws around the import and export of hardware and software; e.g. the US has restrictions around the export of cryptographic technology, and Russia requires a license to import encryption technologies manufactured outside the country
- **International Traffic in Arms Regulations (ITAR):** a US regulation controlling the manufacture, export, and import of military or defense items (e.g. missiles, rockets, bombs, or anything else existing in the United States Munitions List (USML))
- The Export Administration Regulations (EAR): EAR predominantly focuses on commercial use-related items like computers, lasers, marine items, and more; however, it can also include items that may have been designed for commercial use but actually have military applications
- 1.4.4 Transborder data flow
- Orgs should adhere to origin country-specific laws and regulations, regardless of where data resides; also be aware of applicable laws where data is stored and systems are used
- **Wassenaar Arrangement:** multinational agreement, voluntary export control
- 1.4.5 Issues related to privacy (e.g., General Data Protection Regulation (GDPR), California Consumer Privacy Act, Personal Information Protection Law, Protection of Personal Information Act)
- Be familiar with the requirements around healthcare data, credit card data and other PII data as it relates to various countries and their laws and regulations
- California SB 1386 (2002): immediate disclosure to individuals for PII breach
- **California Consumer Privacy Act (CCPA):** The CCPA applies to:
  - For-profit businesses that collect consumers' personal information (or have others collect personal information for them)
  - Determine why and how the information will be processed
  - Do business in California and meet any of the following:
    - have a gross annual revenue > \$25 million;

- buy, sell, or share the personal information of 100k or more California residents or households; or
- get 50% or more of their annual revenue from selling or sharing California residents' personal information
- The CCPA imposes separate obligations on service providers and contractors (who contract with businesses to process personal info) and other recipients of personal information from businesses
- The CCPA does not generally apply to nonprofit orgs or government agencies
- California residents have the right to:
  - (L)imit use and disclosure of personal info
  - (O)pt-out of sale or cross-context advertising
  - (C)orrect inaccurate info
  - (K)now what personal info business have and share
  - (E)qual treatment / nondiscrimination
  - (D)elete info business have on them
- See the National Conference of State Legislatures (NCSL) [list of state-based data breach notifications](#)
- **Children's Online Privacy Protection Act (COPPA)** of 1998:
  - COPPA makes a series of demands on websites that cater to children or knowingly collect information from children:
    - Websites must have a privacy notice that clearly states the types of info they collect and what it's used for (including whether info is disclosed to third parties); must also include contact info for site operators
    - Parents must be able to review any info collected from children and permanently delete it from the site's records
    - Parents must give verifiable consent to the collection of info about children younger than the age of 13 prior to any such collection
- **Clarifying Lawful Overseas Use of Data (CLOUD):** act allowing law enforcement to gather digital evidence from US companies regardless of where the data is stored
  - US government can make bilateral agreements with other countries to provide reciprocal rights
  - US-based companies must comply with lawful orders for data disclosure from foreign governments
  - Companies are provided a mechanism to challenge data requests
- **Electronic Communication Privacy Act (ECPA):** as amended, protects wire, oral, and electronic communications while those communications are being made, are in transit, and when they are stored on computers; makes it a crime to invade electronic privacy of an individual, and it broadened the Federal Wiretap Act
- **Electronic Espionage Act of 1996:** the EEA was enacted to address the threat of trade secret theft, misappropriations, or economic espionage by foreign entities changing the definition of theft so it was no longer restricted by physical constraints
- **Family Education Rights and Privacy Act (FERPA):** Grants privacy rights to students over 18, and the parents of minor students
- **Fourth Amendment to the US Constitution:** the right of the people to be secure in their persons, houses, papers, effects against unreasonable search and seizure

- **General Data Protection Regulation (GDPR):** replaced Data Protection Directive (DPD), purpose is to provide a single, harmonized law that covers data throughout the EU
  - Key aspects:
    - Lawfulness, fairness, and transparency
    - Purpose Limitation
    - Data Minimization
    - Accuracy
    - Storage Limitation
    - Security
    - Accountability
  - GDPR's privacy rules apply to any org anywhere that stores or processes the personal data of EU residents; these individuals must be told how their data is collected and used, and they must be able to opt out
  - Be familiar with the EU Data Protection Directive (Directive 95/46/EC, which was superseded by GDPR)
- GLBA: see above
- HIPAA: (see above) note that HITECH updated many of HIPAA's privacy and security requirements, including requiring a written contract between a HIPAA-covered entity and their business associates (e.g. orgs that handle PHI on their behalf)
- HITECH: (see above) note that notification required by HIPAA-covered entities within 60 days of discovery when more than 500 individuals are affected
- **Organization for Economic Co-operation and Development (OECD):** 8 best practices privacy principles: collection limitation, data quality, purpose specification, use limitation, security safeguards, openness, individual participation, and accountability; require orgs to avoid unjustified obstacles to trans-border data flow, set limits to personal data collection, protect personal data with reasonable security and more
- **Privacy Act of 1974:** a US federal law designed to protect individuals' personal information held by federal government agencies, mandating that agencies only keep records necessary for conducting their business, and procedures for people to get access to the government maintained records
- **Personal Information Protection and Electronic Documents Act (PIPEDA):** Canadian law that governs the use of personal information
- **Personal Information Protection Law (PIPL):** comprehensive Chinese data privacy law, with similarities to GDPR
  - Key aspects of PIPL:
    - Consent and purpose: explicit consent is required for data aggregation and processing, and individuals can withdraw consent
    - Minimum Data Collection: PIPL requires orgs to collect only relevant and necessary personal data
    - Data Subject Rights: provides people with rights to access, correction, deletion, and to be informed of data breaches
    - Cross-Border Data Transfer: imposes restrictions on transferring personal data outside of China
- **Privacy Shield:** (formerly the EU-US Safe Harbor agreement): controls data flow from the EU to the United States; the EU has more stringent privacy protections and without the Privacy Shield, personal data flow from the EU to the United States would not be allowed

- note that the EU-US Privacy Shield was invalidated by the Court of Justice of the European Union (CJEU) in the "Schrems II" ruling (July 2020) and has been replaced by the EU-US Data Privacy Framework (DPF) adopted in July 2023
- **Protection of Personal Information Act (POPIA):** South Africa's comprehensive data protection law designed to protect personal information processed by public and private entities, and promote the right to privacy
  - Key provisions of POPIA:
    - Applies to any organization processing PII of natural or juristic persons in SA
    - Eight conditions for lawful processing
      - accountability
      - processing limitation (minimality and consent)
      - purpose specification
      - information quality
      - openness
      - security safeguards
      - data subject participation
      - limitation on further processing
    - Consent required from data subject to process data, or from a parent or guardian if the subject is a child
    - Strict conditions on special personal information (race, religion, trade union membership, political affiliation etc)
    - Restricts cross-border information transfers unless recipient country has similar privacy protections
    - Penalties for POPIA violation can be severe, enforced by the Information Regulator
- **US Patriot Act of 2001:** enacted following the September 11 attacks with the stated goal of tightening U.S. national security, particularly as it related to foreign terrorism
  - The act included three main provisions:
    - expanded surveillance abilities of law enforcement, including by tapping domestic and international phones
    - easier interagency communication to allow federal agencies to more effectively use all available resources in counter-terrorism efforts, allowing government to obtain detailed information on user activity through a subpoena, and ISPs can voluntarily provide a large range of information to the government
    - increased penalties for terrorism crimes and an expanded list of activities which would qualify for terrorism charges
- 1.4.6 Contractual, legal, industry standards, and regulatory requirements
- Understand the difference between criminal, civil, and administrative law
  - **Criminal law:** protects society against acts that violate the basic principles we believe in; violations of criminal law are prosecuted by federal and state governments
  - **Civil law:** provides the framework for the transaction of business between people and organizations; violations of civil law are brought to the court and argued by the two affected parties

- **Administrative law:** used by government agencies to effectively carry out their day-to-day business
- **Compliance:** Organizations may find themselves subject to a wide variety of laws, and regulations imposed by regulatory agencies or contractual obligation
  - **Payment Card Industry Data Security Standard (PCI DSS):** governs the security of credit card information and is enforced through the terms of a merchant agreement between a business that accepts CC payments, and the bank that processes the business' transactions
  - **Sarbanes-Oxley (SOX):** governs publicly traded corps; financial systems may be audited to ensure security controls are sufficient to ensure compliance with SOX; requires top management to individually certify the accuracy of financial info
    - violations include criminal penalties
  - **Gramm-Leach-Bliley Act (GLBA):** affects banks, insurance companies, and credit providers; included a number of limitations on the types of information that could be exchanged even among subsidiaries of the same corp, and required financial institutions to provide written privacy policies to all their customers
  - **Health Insurance Portability and Accountability Act (HIPAA):** privacy and security regulations requiring strict security measures for hospitals, physicians, insurance companies, and other organizations that process or store private medical information about individuals; also clearly defines the rights of individuals who are the subject of medical records and requires organizations that maintain such records to disclose these rights in writing
    - includes criminal penalties for violations
  - **Federal Information Security Management Act (FISMA):** requires federal agencies to implement an information security program that covers the agency's operations and contractors; the Federal Information Security Modernization Act of 2014 amended the 2002 version of FISMA by centralizing federal cybersecurity responsibility within the Department of Homeland Security (DHS) except for defense-related cybersecurity and scope of the DNI (Director of National Intelligence); the Cybersecurity Enhancement Act of 2014 charged NIST with coordination of voluntary nation-wide cybersecurity standards
  - **Electronic Communications Privacy Act (ECPA):** in short, makes it a crime to invade the electronic privacy of an individual; passed in 1986 to expand and revise federal wiretapping and electronic eavesdropping provisions, making it a crime to intercept or procure electronic communications, and includes important provisions that protect a person's wire and electronic communications from being intercepted by another private individual
  - **Digital Millennium Copyright Act (DMCA):** prohibits the circumvention of copyright protection mechanisms placed in digital media and limits the liability of internet service providers for the activities of their users

## **1.5 Understand requirements for investigation types (i.e., administrative, criminal, civil, regulatory, industry standards) (OSG-10 Chpt 19)**

- An investigation will vary based on incident type, e.g. for a financial services company, a financial system compromise might cause a regulatory investigation; a system breach or website compromise might cause a criminal investigation; each type of investigation has special considerations:
  - **Administrative:** internal investigations usually review operational issues or violations of an organization's policies; often tied to HR scenarios, an admin investigation could be part of technical troubleshooting; since these investigations are for internal purposes, they usually have the lowest formality and standards in terms of documentation or procedures compared to other types; admin investigations often focus on finding the root cause of operational issues
  - **Criminal:** a criminal investigation occurs when a crime has been committed and you are working with a law enforcement agency to convict the alleged perpetrator; in such a case, it is common to gather evidence for a court of law, and to share the evidence with the defense
    - You need to gather and handle the information using methods that ensure the evidence can be used in court
    - In a criminal case, a suspect must be proven guilty beyond a reasonable doubt; a higher bar compared to a civil case, which is showing a preponderance of evidence
  - **Civil:** in a civil case, one person or entity sues another, e.g. one company could sue another for a trademark violation
    - A civil case is typically about monetary damages, and doesn't involve criminality
    - In a civil case, a preponderance of evidence is required to secure a victory, differing from criminal cases, where a suspect is innocent until proven guilty beyond a reasonable doubt; evidence collection standards for civil investigations usually are lower than criminal cases
  - **Industry Standards:** an industry standards investigation is intended to determine whether an org is adhering to a specific industry standard or set of standards, such as those associated with PCI DSS; because standards are not laws, these investigations can be related to contractual compliance, and an org may be required to participate in audits or assessments
    - Because industry standards represent well-understood and widely implemented best practices, many orgs try to adhere to them even when they are not required to do so in order to improve security, and reduce operational and other risks
  - **Regulatory:** A regulatory investigation is conducted by a regulatory body, such as the Securities and Exchange Commission (SEC) or Financial Industry Regulatory Authority (FINRA), against an org suspected of an infraction

- Here the org is required to comply with the investigation, e.g., by not hiding or destroying evidence

## **1.6 Develop, document, and implement security policy, standards, procedures and guidelines (OSG-10 Chpt 1)**

- To create a comprehensive security plan, you need the following items: security policy, standards, baselines, guidelines, and procedures
- The top tier of a formalized hierarchical organization security documentation is the security policy
- **Policy:** docs created by and published by senior management describing organizational strategic goals
- A security policy is a document that defines the scope of security needed by the org, discussing assets that require protection and the extent to which security solutions should go to provide the necessary protections
- It defines the strategic security objectives, vision, and goals and outlines the security framework of the organization
- **Acceptable Use Policy (AUP):** the AUP is a commonly produced document that exists as part of the overall security documentation infrastructure
- This policy defines a level of acceptable performance and expectation of behavior and activity; failure to comply with the policy may result in job action warnings, penalties, or termination
- Security Standards, Baselines and Guidelines: once the main security policies are set, the remaining security documentation can be crafted from these policies
- **Policies:** these are high-level documents, usually written by the management team; policies are mandatory, and a policy might provide requirements, but not the steps for implementation
- **Standards:** specific mandates explicitly stating expectations of performance/conformance; more descriptive than policies, standards define compulsory requirements for the homogeneous use of hardware, software, technology, and security controls, uniformly implemented throughout the org
- **Baselines:** defines a minimum level of security that every system throughout the organization must meet; baselines are usually system specific and refer to industry / government standards
  - e.g. a baseline for server builds would be a list of configuration areas that should be applied to every server that is built
  - A Group Policy Object (GPO) in a Windows network is sometimes used to comply with standards; configuration management solutions can also help you establish baselines and spot configurations that are not in alignment
- **Guidelines:** offers recommendations on how standards and baselines should be implemented & serves as an operational guide for security professionals and users



- Guidelines are flexible, and can be customized for unique systems or conditions; they state which security mechanism should be deployed instead of prescribing a specific product or control; they are not compulsory, but are suggested practices and expectations of activity to best accomplish tasks and goals
- **Procedures** (AKA Standard Operating Procedure or SOP): detailed, step-by-step how-to doc that describes the exact actions necessary to implement a specific security mechanism, control, or solution

## **1.7 Identify, analyze, assess, prioritize, and implement Business Continuity (BC) requirements (OSG-10 Chpt 3)**

- 1.7.1 Business Impact Analysis (BIA)
- **Business impact analysis (BIA)**: Identify the systems and services that the business relies on and assess the impacts that a disruption or outage would cause, including the impacts on business processes like accounts receivable and sales
  - Step 1: Identification of priorities
  - Step 2: Risk identification
  - Step 3: Likelihood assessment
  - Step 4: Resource prioritization
    - deciding which systems and services you need to get things running again (think foundational IT services such as the network and directory, which many other systems rely on)
    - and prioritize the order in which critical systems and services are recovered or brought back online
  - As part of the BIA, establish:
    - **recovery time objectives (RTO)**: how long it takes to recover; maximum tolerable time to recover systems to a defined service level
    - **recovery point objectives (RPO)**: the maximum tolerable data loss measured in time
    - **maximum tolerable downtime (MTD) or maximum allowable downtime (MAD)**: the length of time an org can suffer the loss of its critical path or critical functions before ceasing to be a viable enterprise; how long an org can survive an interruption of critical functions
    - **MTTR**: mean time to repair is the average length of time required to perform a repair on the device (also see Domain 7)
    - **MTBF**: mean time between failure is an estimation of time between the first and any subsequent failures (also see Domain 7)
    - along with the costs of downtime and recovery
  - **Continuity planning**: The first two phases of the BCP process (project scope and planning and the business impact analysis) focus on determining how the BCP process will work and prioritizing the business assets that need to be protected against interruption

- The next phase of BCP development, continuity planning, focuses on the development and implementation of a continuity strategy to minimize the impact realized risks might have on protected assets
- There are two primary subtasks/phases involved in continuity planning:
  - **Strategy development:** in this phase, the BCP team determines which risks they will mitigate
  - **Provisions and processes:** in this phase, the team designs mechanisms and procedures that will mitigate identified risks
- The goal of this process is to create a **continuity of operations plan (COOP)**, which focuses on how an org will carry out critical business functions starting shortly after a disruption occurs and extending up to one month of sustained operations
- **Approval and implementation:**
  - BCP plan now needs sr. management buy-in (should be endorsed by the org's top exec)
  - BCP team should create an implementation schedule, and all personnel involved should receive training on the plan
- **Business Continuity Planning (BCP):** involves assessing the risk to organizational processes and creating policies, plans, and procedures to minimize the impact those risks might have on the organization if they were to occur
  - BCP is used to maintain the continuous operation of a business in the event of an emergency, with a goal to implement a combination of policies, procedures, and processes
  - Business continuity requires a lot of planning and preparation; actual implementation of business continuity processes occur quite infrequently
  - The primary facets of business continuity are:
    - Resilience: (e.g. within a data center and between sites or data centers)
    - Recovery: if a service becomes unavailable, you need to recover it as soon as possible
    - Contingency: a last resort in case resilience and recovery prove ineffective
  - The BCP process has four main steps:
    - Project scope and planning
    - Business Impact Analysis
    - Continuity planning
    - Approval and Implementation
- **Project scope and planning:** Developing the project scope and plan starts with gaining support of the management team, making a business case (cost/benefit analysis, regulatory or compliance reasons etc.) and gaining approval to move forward
  - Next, you need to form a team with representatives from the business as well as IT
  - Next, start with a business continuity policy statement, conduct a business impact analysis (see next item), and then develop the remaining components:
    - preventive controls
    - relocation
    - the actual continuity plan
    - testing
    - training and maintenance

- BCP vs DR:
  - BCP activities are typically strategically focused at a high level and center themselves on business processes and operations
  - DR plans tend to be more tactical and describe technical activities such as recovery sites, backups, and fault tolerance
- The overall goal of BCP is to provide a quick, calm, and efficient response in the event of an emergency and to enhance a company's ability to quickly recover from a disruptive event
- 1.7.2 External dependencies
- It's important to explore external party and vendor roles and responsibilities as part of the BCP process to understand and plan for how these organizations/services will impact your organization's contingency plans
  - External party contingency review includes (but is not limited to) vendors supplying critical hardware and software, cloud services, legal/regulatory concerns etc
- The top priority of BCP and DRP is people: **Always prioritize people's safety**; get people out of harm's way, and then address IT recovery and restoration issues

## **1.8 Contribute to and enforce personnel security policies and procedures (OSG-10 Chpt 2)**

- People are often considered the weakest element in any security solution; no matter what physical or logical controls are deployed, humans can discover ways to avoid, circumvent/subvert, or disable them
  - Malicious actors are routinely targeting users with phishing and spear phishing campaigns, social engineering, and other types of attacks, and everybody is a target
  - Once attackers compromise an account, they can use that entry point to move around the network and elevate their privileges
  - People can also become a key security asset when they are properly trained and are motivated to protect not only themselves but the security of the organization as well
  - Part of planning for security includes having standards in place for job descriptions, job classifications, work tasks, job responsibilities, prevention of collusion, candidate screening, background checks, security clearances, employment and nondisclosure agreements
- 1.8.1 Candidate screening and hiring
  - The following strategies can reduce your risk:
    - **Candidate screening and hiring:**
      - screening employment candidates thoroughly is a key part of the hiring process
      - be sure to conduct a full background check that includes a criminal records check, job history verification, education verification, certification validation and confirmation of other accolades when possible
      - all references should be contacted

- 1.8.2 Employment agreements and policies driven requirements
  - **Employment agreement:** specifies job duties, expectations, rate of pay, benefits and info about termination; sometimes, such agreements are for a set period (for example, in a contract or short-term job)
    - Employment agreements facilitate termination when needed for an underperforming employee
    - The more info and detail in an employment agreement, the less risk (risk of a wrongful termination lawsuit, for example) the company has during a termination proceeding
    - e.g. a terminated employee might take a copy of their email with them without thinking of it as stealing, but they are less likely to do so if an employment agreement or another policy document clearly prohibits it
    - example employee agreements:
      - non-compete
      - codes of conduct such as an acceptable use policy (AUP), which defines what is and isn't acceptable activity, practice, or use for company equipment and resources
      - nondisclosure agreement (NDA), which is a doc used to protect confidential information from being disclosed by a current or former employee
    - **Compliance:** the act of confirming or adhering to rules, policies, regulations, standards, or requirements
    - on a personnel level, compliance is related to individual employees following company policies and procedures
    - employees need to be trained on company standards as defined in the security policy and remain in compliance with any contractual obligations (e.g. with PCI DSS)
  - Compliance is a form of administrative or managerial security control
  - **Compliance enforcement:** the application of sanctions or consequences for failing to follow policy, training, best practices, or regulations
  - Personally identifiable information (PII) about employees, partners, contractors, customers and others should be stored in a secure way, accessible only to those who require the information to perform their jobs
  - Orgs should maintain a documented privacy policy outlining the type of data covered by the policy and who the policy applies to
  - Employees and contractors should be required to read and agree to the privacy policy upon hire and on a regular basis thereafter (such as annually)
- 1.8.3 Onboarding, transfers and termination processes
  - **Onboarding:** process of bringing a new employee into the org
    - creating documented processes allowing the new employee to be integrated quickly and consistently
  - **Transfer:** an employee moves from one job to another, likely requiring adjusted account access to maintain appropriate least privilege

- **Termination or offboarding:** offboarding is the removal of an employee's identity from the IAM system, once that person has left the org; can also be an element used when an employee transfers into a new role
  - whether cordial or abrupt, the ex-employee should be escorted off the premises and not allowed to return
- 1.8.4 Vendor, consultant, and contractor agreements and controls
  - Orgs commonly outsource many IT functions, particularly data center hosting, contact-center support, and application development
  - Info security policies and procedures must address outsourcing security and the use of service providers, vendors and consultants
    - e.g. access control, document exchange and review, maintenance, on-site assessment, process and policy review, and Service Level Agreements (SLAs) are examples of outsourcing security considerations

## **1.9 Understand and apply risk management concepts (OSG-10 Chpt 2)**

- 1.9.1 Threat and vulnerability identification
  - **Risk Management:** process of identifying factors that could damage or disclose data, evaluating those factors in light of data value and countermeasure cost, and implementing cost-effective solutions for mitigating or reducing risk
  - **Threat:** any potential occurrence that may cause an undesirable or unwanted outcome for a specific asset; they can be intentional or accidental; loosely think of a threat as a weapon that could cause harm to a target
  - **Vulnerability:** the weakness in an asset, or weakness (or absence) of a safeguard or countermeasure; a flaw, limitation, error, frailty, or susceptibility to harm
  - Threats and vulnerabilities are related: a threat is possible when a vulnerability is present
    - Threats exploit vulnerabilities, which results in exposure
    - Exposure is risk, and risk is mitigated by safeguards
    - Safeguards protect assets that are endangered by threats
    - **Threat Agent/Actor:** intentionally exploit vulnerabilities
    - **Threat Event:** accidental occurrences and intentional exploitations of vulnerabilities
    - **Threat Vector:** (AKA attack vector) is the path or means by which an attack or attacker can gain access to a target in order to cause harm
    - **Exposure:** being susceptible to asset loss because of a threat; the potential for harm to occur
    - **Exposure Factor (EF):** derived from this concept; an element of quantitative risk analysis that represents the percentage of loss that an org would experience if a specific asset were violated by a realized risk

- **Single Loss Expectancy (SLE):** an element of quantitative risk analysis that represents the cost associated with a single realized risk against a specific asset;
    - $SLE = \text{asset value (AV)} * \text{exposure factor (EF)}$
    - Where EF is a metric that represents the loss a realized threat would have on a specific asset, quantified as a percentage: e.g. an EF of 0.2 (or 20%) for a specific threat would indicate that a realization of that threat would result in a loss of 20% of the asset's value
    - Note that EF is not a fixed number for an asset, but is a unique value determined by a specific threat affecting a specific asset
  - **Annualized rate of occurrence (ARO):** an element of quantitative risk analysis that represents the expected frequency with which a specific threat or risk will occur within a single year
  - **Annualized loss expectancy (ALE):** an element of quantitative risk analysis that represents the possible yearly cost of all instances of a specific realized threat against a specific asset
    - $ALE = SLE * ARO$
  - **Safeguard evaluation:** ALE for an asset if a safeguard is implemented
    - ALE before safeguard - ALE with safeguard - annual cost of safeguard
    - or  $(ALE1 - ALE2) - ACS$
  - **Risk:** the possibility or likelihood that a threat will exploit a vulnerability to cause harm to an asset and the severity of damage that could result; the greater the potential harm, the greater the risk
  - **risk appetite** vs. **risk tolerance** vs. **risk capacity** are commonly tested concepts:
  - **Risk appetite:** the total amount of risk an organization is willing to accept
  - **Risk tolerance:** the acceptable level of variation in outcomes relative to a specific objective
  - **Risk capacity:** the maximum amount of risk an organization can support or absorb
- 1.9.2 Risk analysis, assessment, and scope
    - **Risk Assessment:** used to identify the risks and set criticality priorities, and then risk response is used to determine the best defense for each identified risk
    - Risk is threat with a vulnerability
    - $\text{Risk} = \text{threat} * \text{vulnerability}$  (or probability of harm multiplied by severity of harm)
    - Addressing the threat, threat agent or vulnerability directly results in a reduction of risk (known as threat mitigation)
    - All IT systems have risk; all orgs have risk; there is no way to eliminate 100% of all risks
      - Instead upper management must decide which risks are acceptable, and which are not; there are two primary risk-assessment methodologies:
        - **Quantitative Risk Analysis:** assigns real dollar figures to the loss of an asset and is based on mathematical calculations

- **Qualitative Risk Analysis:** assigns subjective and intangible values to the loss of an asset and takes into account perspectives, feelings, intuition, preferences, ideas, and gut reactions; qualitative risk analysis is based more on scenarios than calculations, and threats are ranked to evaluate risks, costs, and effects
  - Most orgs employ a hybrid of both risk assessment methodologies
  - The goal of risk assessment is to identify risks (based on asset-threat pairings) and rank them in order of criticality
- 1.9.3 Risk response and treatment (e.g. cybersecurity insurance)
  - **Risk response:** the formulation of a plan for each identified risk; for a given risk, you have a choice for a possible risk response:
    - **Risk Mitigation:** reducing risk, or risk mitigation, is the implementation of safeguards, security controls, and countermeasures to reduce and/or eliminate vulnerabilities or block threats
    - **Risk Assignment:** assigning or transferring risk is the placement of the responsibility of loss due to a risk onto another entity or organization; AKA assignment of risk and transference of risk
    - **Risk Deterrence:** deterrence is the process of implementing deterrents for would-be violators of security and policy
      - the goal is to convince a threat agent not to attack
      - e.g. implementing auditing, security cameras, and warning banners; using security guards
    - **Risk Avoidance:** determining that the impact or likelihood of a specific risk is too great to be offset by potential benefits, and not performing a particular business function due to that determination; the process of selecting alternate options or activities that have less associated risk than the default, common, expedient, or cheap option
    - **Risk Acceptance:** the result after a cost/benefit analysis determines that countermeasure costs would outweigh the possible cost of loss due to a risk
      - also means that management has agreed to accept the consequences/loss if the risk is realized
    - **Risk Rejection:** an unacceptable possible response is to reject risk or ignore risk; denying that risk exists and hoping that it will never be realized are not valid prudent due care/due diligence responses to risk
    - **Risk Transference:** paying an external party (i.e. an insurance company) to accept the financial impact of a given risk
  - **Inherent Risk:** the level of natural, native, or default risk that exists in an environment, system, or product prior to any risk management efforts being performed (AKA initial or starting risk); this is the risk identified by the risk assessment process
  - **Residual Risk:** consists of threats to specific assets against which management chooses not to implement (the risk that management has chosen to accept rather than mitigate); risk remaining after security controls have been put in place
  - **Total Risk:** the amount of risk an org would face if no safeguards were implemented
  - **Conceptual Total Risk Formula:** threats x vulnerabilities x asset value = total risk

- **Controls Gap:** amount of risk that is reduced by implementing safeguards, or the difference between total risk and residual risk
- **Conceptual Residual Risk Formula:** total risk - controls gap = residual risk
- Risk should be reassessed on a periodic basis to maintain reasonable security because security changes over time
- **Countermeasure:** AKA a "control" or "safeguard" can help reduce risk
  - For exam prep, understand how the concepts are integrated into your environment; this is not a step-by-step technical configuration, but the process of the implementation — where you start, in which order it occurs and how you finish
  - Bear in mind that security should be designed to support and enable business tasks and functions
    - security controls, countermeasures, and safeguards can be implemented administratively, logically / technically, or physically
    - these 3 categories should be implemented in a conceptual layered defense-in-depth manner to provide maximum benefit
    - based on the concept that policies (part of administrative controls) drive all aspects of security and thus form the initial protection layer around assets
    - then, logical and technical controls provide protection against logical attacks and exploits
    - then, physical controls provide protection against real-world physical attacks against facilities and devices
- 1.9.4 Applicable types of controls (e.g., preventive, detection, corrective)
  - Three ways to implement mitigating controls:
    - **Administrative:** the policies and procedures defined by an org's security policy and other regulations or requirements
    - **Technical / Logical:** examples include firewalls, automated backups, encryption
    - **Physical:** security mechanisms focused on providing protection to the facility and real world objects
  - Safeguards:
    - **Preventive:** a preventive or preventative control is deployed to thwart or stop unwanted or unauthorized activity from occurring
    - **Deterrent:** a deterrent control is deployed to discourage security policy violations; deterrent and preventative controls are similar, but deterrent controls often depend on individuals being convinced not to take an unwanted action
    - **Directive:** A directive control is deployed to direct, confine, or control the actions of subjects to force or encourage compliance with security policies
  - Countermeasures:
    - **Detective:** a detective control is deployed to discover or detect unwanted or unauthorized activity; detective controls operate after the fact



- **Corrective:** a corrective control modifies the environment to return systems to normal after an unwanted or unauthorized activity has occurred; it attempts to correct any problems resulting from a security incident
- **Recovery:** An extension of corrective controls but have more advanced or complex abilities; a recovery control attempts to repair or restore resources, functions, and capabilities after a security policy violation
- recovery controls typically address more significant damaging events compared to corrective controls, especially when security violations may have occurred
- **Compensating:** a compensating control is deployed to provide various options to other existing controls, to aid in enforcement and support of security policies
  - they can be any controls used in addition to, or in place of, another control
  - they can be a means to improve the effectiveness of a primary control or as the alternative or failover option in the event of a primary control failure
- 1.9.5 Control assessments (e.g. security and privacy)
  - **Security Control Assessment (SCA):** formal evaluation and review of individual controls against a baseline; tests if an organization's security controls (technical, administrative, and physical) are implemented correctly, functioning as intended and meeting security requirements
  - basically a formal evaluation of a defined set of controls against a baseline or reliability expectation; may be conducted with the Security Test and Evaluation (ST&E); [NIST Special Publication 800-53A Security and Privacy Controls for Federal Information Systems and Organizations](#) ensure the security requirements and enforcement of appropriate security controls
  - goals of SCA:
    - ensure the effectiveness of the security mechanisms
    - evaluate the quality and thoroughness of the risk management processes
    - produce a report of the relative strengths and weaknesses of the deployed security infrastructure
  - An SCA goal is to ensure security mechanism effectiveness; periodically assess security and privacy controls to determine what's working, what isn't
    - As part of this assessment, the existing documents should be thoroughly reviewed, and some of the controls tested randomly
    - A report is typically produced to show the outcomes and enable the org to remediate deficiencies
    - Often, security and privacy control assessments are performed and/or validated by different teams, with the privacy team handling the privacy aspects
  - For federal agencies, an SCA process generally is based on SP 800-53
- 1.9.6 Continuous monitoring and measurement
  - Monitoring and measurement are closely aligned with identifying risks

- While monitoring is used for more than security purposes, monitoring should be tuned to ensure the org is notified about potential security incidents as soon as possible
- If a security breach occurs, monitored systems and data become valuable from a forensics perspective; from the ability to derive root cause of an incident to making adjustments to minimize the chances of reoccurrence
- 1.9.7 Reporting (e.g., internal, external)
  - Risk Reporting is a key task to perform at the conclusion of risk analysis (i.e. production and presentation of a summarizing report)
  - A Risk Register or Risk Log is a document that inventories all identified risks to an org or system or within an individual project
    - A risk register is used to record and track the activities of risk management, including:
      - identifying risks
      - evaluating the severity of, and prioritizing those risks
      - prescribing responses to reduce or eliminate the risks
      - track the progress of risk mitigation
- 1.9.8 Continuous improvement (e.g., risk maturity modeling)
  - Risk analysis is performed to provide upper management with the details necessary to decide which risks should be mitigated, which should be transferred, which should be deterred, which should be avoided, and which should be accepted; to fully evaluate risks and subsequently take proper precautions, the following must be analyzed:
    - assets
    - asset valuation
    - threats
    - vulnerabilities
    - exposure
    - risk
    - realized risk
    - safeguards
    - countermeasures
    - attacks
    - breaches
  - An **Enterprise Risk Management** (ERM) program can be evaluated using an RMM
  - **Risk Maturity Model (RMM)**: assesses the key indicators and activities of a mature, sustainable, and repeatable risk management process, typically relating the assessment of risk maturity against a five-level model such as:
    - **Ad hoc**: a chaotic starting point from which all orgs initiate risk management
    - **Preliminary**: loose attempts are made to follow risk management processes, but each department may perform risk assessment uniquely
    - **Defined**: a common or standardized risk framework is adopted organization-wide

- **Integrated:** risk management operations are integrated into business processes, metrics are used to gather effectiveness data, and risk is considered an element in business strategy decisions
  - **Optimized:** risk management focuses on achieving objectives rather than just reacting to external threats; increased strategic planning is geared toward business success rather than just avoiding incidents; and lessons learned are re-integrated into the risk management process
- 1.9.9 Risk frameworks (e.g., International Organization for Standardization (ISO), National Institute of Standards and Technology (NIST), Control Objectives for Information and Related Technology (COBIT), Sherwood Applied Business Security Architecture (SABSA), Payment Card Industry (PCI))
  - See section 1.3.4 above for definitions of these frameworks
  - A risk framework is a guide or recipe for how risk is to be assessed, resolved, and monitored
  - NIST established the **Risk Management Framework (RMF)** and the **Cybersecurity Framework (CSF)**: the CSF is a set of guidelines for mitigating organizational cybersecurity risks, based on existing standards, guidelines, and practices
  - The RMF is intended as a risk management process to identify and respond to threats, and is defined in three core, interrelated Special Publications:
    - SP 800-37 Rev 2, Risk Management Framework for Information Systems and Organizations
    - SP 800-39, Managing Information Security Risk
    - [SP 800-30 Rev 1, Guide for Conducting Risk Assessments](#) outlines four primary steps to conduct a risk assessment
      - Prepare for the assessment
      - Conduct assessment
        - identify threat sources and events
        - identify vulnerabilities and predisposing conditions
        - determine likelihood of occurrence
        - determine magnitude of impact
        - determine risk
      - Communicate results
      - Maintain assessment
  - The **RMF has 7 steps**, and **six cyclical phases**:
    - **Prepare** to execute the RMF from an organization and system-level perspective by establishing a context and priorities for managing security and privacy risk
    - **Categorize** the system and the information processed, stored, and transmitted by the system based on an analysis of the impact of loss
    - **Select** an initial set of controls for the system and tailor the controls as needed to reduce risk to an acceptable level based on an assessment of risk
    - **Implement** the controls and describe how the controls are employed within the system and its environment of operation

- **Assess** the controls to determine if the controls are implemented correctly, operating as intended, and producing the desired outcomes with respect to satisfying the security and privacy requirements
- **Authorize** the system or common controls based on a determination that the risk to organizational operations and assets, individuals, and other organizations, and the nation is acceptable
- **Monitor** the system and associated controls on an on-going basis to include assessing control effectiveness, documenting changes to the system and environment of operation, conducting risk assessments and impact analysis, and reporting the security and privacy posture of the system
- See my overview article, [The NIST Risk Management Framework](#)
- There are other risk frameworks, such as the ISO/IEC 31000, ISO/IEC 31004, COSO's ERM, ISACA's Risk IT, OCTAVE, FAIR, and TARA (transfer, avoid, reduce, and accept); be familiar with frameworks and their goals

## **1.10 Understand and apply threat modeling concepts and methodologies (OSG-10 Chpt 1)**

- **Threat Modeling:** security process where potential threats are identified, categorized, and analyzed; can be performed as a **proactive** measure during design and development (aka **defensive approach**) or as a **reactive** measure once a product has been deployed (aka **adversarial approach**)
  - Threat modeling identifies the potential harm, the probability of occurrence, the priority of concern, and the means to eradicate or reduce the threat
- **MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge):** a comprehensive framework with a globally accessible knowledge base that documents real-world tactics, techniques, and procedures (TTPs) used by cyber adversaries; it is widely used by organizations to improve threat detection, incident response, and cybersecurity defenses; ATT&CK is used as a default model in many software packages
- Microsoft uses the **Security Development Lifecycle (SDL)** with the motto: "Secure by design, secure by default, secure in deployment and communication"
  - It has two objectives:
    - Reduce the number of security-related design and coding defects
    - Reduce the severity of any remaining defects
- A defensive approach to threat modeling takes place during the early stages of development; the method is based on predicting threats and designing in specific defenses during the coding and crafting process
  - Security solutions are more cost effective in this phase than later; this concept should be considered a proactive approach to threat management
- Microsoft developed the **STRIDE threat model**:
  - Spoofing: an attack with the goal of gaining access to a target system through the use of falsified identity

- Tampering: any action resulting in unauthorized changes or manipulation of data, whether in transit or in storage
- Repudiation: the ability of a user or attacker to deny having performed an action or activity by maintaining plausible deniability
- Information Disclosure: the revelation or distribution of private, confidential, or controlled information to external or unauthorized entities
- **Denial of Service (DoS)**: an attack that attempts to prevent authorized use of a resource; this can be done through flaw exploitation, connection overloading, or traffic flooding; for example, a SYN flood is a DoS attack that disrupts the TCP three-way handshake
- Elevation of privilege: an attack where a limited user account is transformed into an account with greater privileges, powers, and access
- STRIDE is threat categorization model; threat categorization is an important part of app threat modeling
- **Process for Attack Simulation and Threat Analysis (PASTA)**: a seven-stage threat modeling methodology:
  - Stage I: Definition of the Objectives (DO) for the Analysis of Risk
  - Stage II: Definition of the Technical Scope (DTS)
  - Stage III: Application Decomposition and Analysis (ADA)
  - Stage IV: Threat Analysis (TA)
  - Stage V: Weakness and Vulnerability Analysis (WVA)
  - Stage VI: Attack Modeling and Simulation (AMS)
  - Stage VII: Risk Analysis and Management (RAM)
- Each stage of PASTA has a specific list of objectives to achieve and deliverables to produce in order to complete the stage
- **Visual, Agile, and Simple Threat (VAST)**: a threat modeling concept that integrates threat and risk management into an Agile programming environment on a scalable basis
- Part of the job of the security team is to identify threats, using different methods:
  - Focus on attackers: this is a useful method in specific situations
    - e.g. suppose that a developer's employment is terminated, and that post-offboarding and review of developer's computer, a determination is made that the person was disgruntled and angry
    - understanding this situation as a possible threat, allows mitigation steps to be taken
  - Focus on assets: an org's most valuable assets are likely to be targeted by attackers
  - Focus on software: orgs that develop applications in house, and can be viewed as part of the threat landscape; the goal isn't to identify every possible attack, but to focus on the big picture, identifying risks and attack vectors
- Understanding threats to the org allow the documentation of potential attack vectors; diagramming can be used to list various technologies under threat
- **Reduction analysis**: with a purpose of gaining a greater understanding of the logic of a product and interactions with external elements includes breaking down a system into five core elements: trust boundaries, data flow paths, input points, privileged operations, and security control details; AKA decomposing the application, system, or environment
- **DREAD**: Microsoft developed the DREAD threat modeling approach to detect and prioritize threats so that serious threats can be mitigated first

- D: Damage potential
- R: Reproducibility
- E: Exploitability
- A: Affected users
- D: Discoverability
- Note that STRIDE and DREAD are used together: STRIDE to identify the threats, DREAD to prioritize them
- **Trike**: an open source risk-based threat modeling methodology; provides a method of performing a reliable and repeatable security audit, and a framework for collaboration and communication
- Also see Cyber Kill Chain in Domain 7
- Threat intelligence feed standards include:
  - **CAPEC (Common Attack Pattern Enumeration and Classification)**: a dictionary of known attack patterns
  - **STIX (Structured Threat Information eXpression language)**: used to describe threats in a standardized way
  - **TAXII (Trusted Automated eXchange of Indicator Information)**: defines how threat information can be shared and exchanged

## **1.11 Apply Supply Chain Risk Management (SCRM) concepts (OSG-10 Chpt 1)**

- 1.11.1 Risks associated with the acquisition of products and services from suppliers and providers (e.g., product tampering, counterfeits, implants)
  - **Supply Chain Risk Management (SCRM)**: the means to ensure that all of the vendors or links in the supply chain are:
    - reliable,
    - trustworthy,
    - reputable organizations that disclose their practices and security requirements to their business partners (not necessarily to the public)
  - Each link in the chain should be responsible and accountable to the next link in the chain; each handoff is properly organized, documented, managed, and audited
    - The goal of a secure supply chain is that the finished product is of sufficient quality, meets performance and operational goals, provides stated security mechanisms, and that at no point in the process was any element counterfeited or subject to unauthorized or malicious manipulation or sabotage
  - The supply chain can be a threat vector, where materials, software, hardware, or data are obtained from a supposedly trusted source but the supply chain behind the source could have been compromised and asset poisoned or modified
  - Supply chain attacks include things like product tampering, counterfeits, or implants; these attacks can be difficult to detect, and changes or manipulations can be made via hardware (even miniaturized chips), or via software

- choosing trusted and reputable vendors, and doing security monitoring, management and assessments are important to lower these risks
- 1.11.2 Risk mitigations (e.g., third-party assessment and monitoring, minimum security requirements, service level requirements, silicon root of trust, physically unclonable function, software bill of materials)
  - Before doing business with another company, an org needs to perform due-diligence, and third-party assessments can help gather information and perform the assessment
  - An on-site assessment is useful to gain information about physical security and operations
    - During document review, your goal is to thoroughly review all the architecture, designs, implementations, policies, procedures, etc.
    - A good understanding of the current state of the environment, especially to understand any shortcomings or compliance issues prior to integrating the IT infrastructures
    - The level of access and depth of information obtained is usually proportional to how closely the companies will work together
  - Creating security requirements that dovetail with SLAs and contracts is important, as are including things like a **silicon root of trust (RoT)** (AKA hardware root of trust) to ensure the integrity, authenticity, and confidentiality as a foundation of system startup security
  - **Physically unclonable function (PUF)**: physical component that creates a unique digital identifier that can create an electronic fingerprint for integrated circuits or devices
  - **Software Bill of Materials (SBOM)**: a detailed list of all components, libraries, and dependencies (including open-source and proprietary code) included in a software app; the purpose is to provide better software transparency, security and compliance helping teams address risks and track vulnerabilities

## **1.12 Establish and maintain a security awareness, education, and training program (OSG-10 Chpt 2)**

- 1.12.1 Methods and techniques to increase awareness and training (e.g., social engineering, phishing, security champions, gamification)
  - Before actual training takes place, user security awareness needs to take place; from there, training, or teaching employees to perform their work tasks and to comply with the security policy can begin
    - All new employees require some level of training so that they will be able to comply with all standards, guidelines, and procedures mandated by the security policy
    - Education is a more detailed endeavor in which students/users learn much more than they actually need to know to perform their work tasks
    - Education is most often associated with users pursuing certification or seeking job promotion

- Employees need to understand what to be aware of (e.g. types of threats, such as phishing and free USB sticks), how to perform their jobs securely (e.g. encrypt sensitive data, physically protect valuable assets) and how security plays a role in the big picture (company reputation, profits, and losses)
  - Training should be mandatory and provided both to new employees and yearly (at a minimum) for ongoing training
  - Routine tests of operational security should be performed (such as phishing test campaigns, tailgating at company doors and social engineering tests)
  - **Social engineering:** a form of attack that exploits human nature and behavior; the common social engineering principles are authority, intimidation, consensus, scarcity, familiarity, trust, and urgency
    - **familiarity:** as a social engineering principle, an attempt to exploit someone's native trust in things that are familiar; might include claiming to know a coworker (existing or not), and designed to put the target in a mindset that promotes willingness to provide info
    - social engineering attacks include phishing, spear phishing, business email compromise (BEC), whaling, smishing, vishing, spam, shoulder surfing, invoice scams, hoaxes, impersonation, masquerading, tailgating, piggybacking, dumpster diving, identity fraud, typo squatting, and influence campaigns
    - while many orgs don't perform social engineering campaigns (testing employees using benign social engineering attempts) as part of security awareness, it is likely to gain traction
    - outside of campaigns, presenting social engineering scenarios and information is a common way to educate
  - Phishing: phishing campaigns are popular, and many orgs use third-party services to routinely test their employees with fake phishing emails
    - such campaigns produce valuable data, such as the percentage of employees who open the phishing email, the percentage who open attachments or click links, and the percentage who report the fake phishing email as malicious
  - Security champions: the term "champion" has been gaining ground; orgs often use it to designate a person on a team who is a subject matter expert in a particular area or responsible for a specific area
    - e.g. somebody on the team could be a monitoring champion — they have deep knowledge around monitoring and evangelize the benefits of monitoring to the team or other teams
    - a security champion is a person responsible for evangelizing security, helping bring security to areas that require attention, and helping the team enhance their skills
  - Gamification: legacy training and education are typically based on reading and then answering multiple-choice questions to prove knowledge; gamification aims to make training and education more fun and engaging by packing educational material into a game
    - gamification has enabled organizations to get more out of the typical employee training



- **Security champions:** team member who acts as the liaison between their team and the security team, promoting secure development practices and helping integrate security into daily workflows
- 1.12.2 Periodic content reviews to include emerging technologies and trends (e.g., cryptocurrency, artificial intelligence (AI), blockchain)
  - On-going training (or teaching people how to perform their tasks and comply with policies) and education (teaching students/users more than they need to know to perform specific tasks) is important as is developing security champions
  - It's also important to periodically review training material content, especially in regard to the fast pace of change of newer technologies such as AI, blockchain and even cryptocurrencies
    - emerging tech trends should be incorporated into training materials
    - not only material updates, but methods should also be updated to keep content and approach relevant and from getting stale
  - Threats are complex, so training needs to be relevant and interesting to be effective; this means updating training materials and changing out the ways which security is tested and measured
    - if you always use the same phishing test campaign or send it from the same account on the same day, it isn't effective, and the same applies to other materials
    - instead of relying on long/detailed security documentation for training and awareness, consider using internal social media tools, videos and interactive campaigns
- 1.12.3 Program effectiveness evaluation
  - Time and money must be allocated for evaluating the company's security awareness and training; the company should track key metrics, such as the percentage of employees who click on a fake phishing campaign email links

Also see [Understanding CISSP Domain 1: Security and Risk Management](#) on my blog, [The Cyber Leader](#) for additional information

Articles on risk management:

- [Part 1](#) introduces risk and risk terminology from the lens of the (ISC)<sup>2</sup> Official Study Guide
- Since the primary goal of risk management is to identify potential threats against an organization's assets, and bring those risks into alignment with an organization's risk appetite, in [Part 2](#), we cover the threat assessment -- a process of examining and evaluating cyber threat sources with potential system vulnerabilities
  - we look at how a risk assessment helps drive our understanding of risk by pairing assets and their associated potential threats, ranking them by criticality
  - we also discuss quantitative analytic tools to help provide specific numbers for various potential risks, losses, and costs
- In the [Part 3](#), we review the outcome of the risk assessment process, looking at total risk, allowing us to determine our response to each risk/threat pair and perform a cost/benefit review of a particular safeguard or control

- we look at the categories and types of controls and the idea of layering them to provide several different types of protection mechanisms
- we also review the important step of reporting out our risk analysis and recommended responses, noting differences in requirements for messaging by group